

AI Agents & Security

By Rod Soto
rodsoto.net

\$whoami

Rod Soto
rodsoto.com

AI Agents - What are they?

An agent is a smart application that leverages the use of LLMs to perform specific workflows where they make decisions and take actions.

All these workflows are based on several elements:

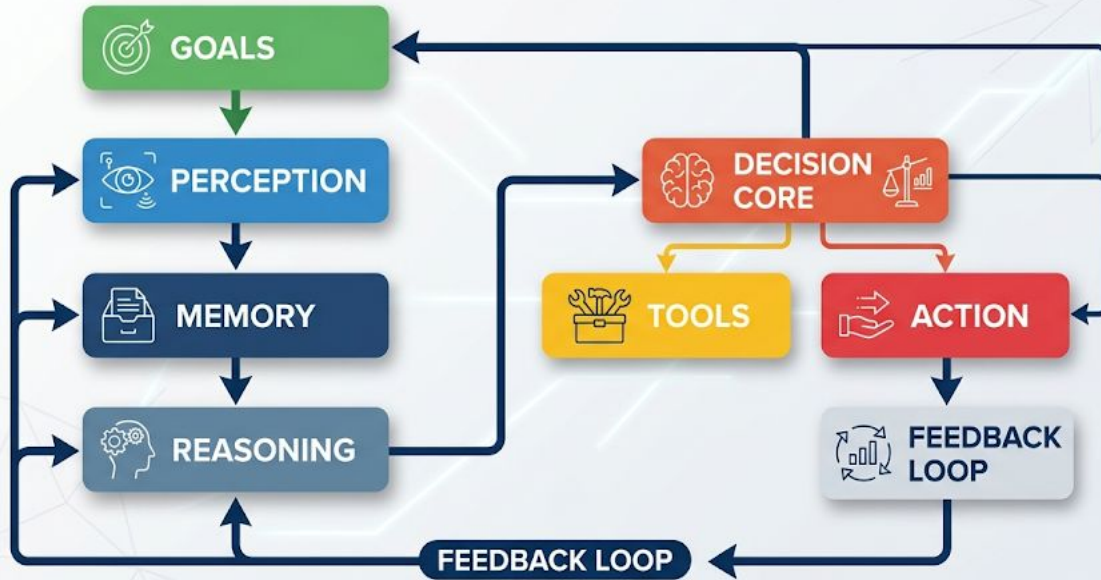
- LLMs (Reasoning & Inference)
- Tools (APIs, DBs, MCPs)
- Goal oriented steps (Architecture, Frameworks)

Components of an AI Agent

- **Goals:** What the agent is trying to achieve
- **Perception:** Inputs from the environment (user input, data, signals)
- **Memory:** Where context and past knowledge is kept (short term, long term)
- **Reasoning:** A decision on what to do next in terms of single or multiple steps
- **Decision Core:** LLM in use (System Prompts)
- **Tools:** External Capabilities (APIs, MCP, Systems, Databases, Files)
- **Action:** Execute Actions
- **Feedback Loop:** Observes results and adjust behavior

Agent Workflows

PERCEPTION-TO-ACTION WORKFLOW



AI Agent Architecture

- **ReAct-style agent**

- One agent loop that reads input, reasons, calls tools, and returns an answer.
- Common in “copilot” or workflow bots that handle linear tasks with tool calls (search, DB, API) and optional memory.

When to use?

- **Simple, mostly stateless workflows; chatbots with tools; single-user assistants.**

- **Plan-and-execute (planner–executor)**

- A “planner” agent decomposes a goal into steps, then “executor” agents or routines carry out each step.

When to use:?

- Multi-step workflows (research → transform → act), scripted business processes, testable pipelines.

AI Agent Architecture

- **Self-reflection / self-improvement agents**

- The agent critiques its own outputs and tries again, often via an explicit “reflection” phase.
- This can be combined with plan-and-execute (plan → act → reflect → refine).

When to use?

- Tasks that benefit from iterative improvement (coding, data analysis, report drafting) and can tolerate extra latency.

- **Role-based multi-agent “crew” architectures**

- Multiple agents, each with a fixed **role** and goal (e.g., Researcher, Domain Expert, Critic, Editor) collaborating via messages.
- Often implemented in frameworks like CrewAI, AutoGen, or LangGraph as a group chat or graph of agents

When to use?

Content workflows, customer-support swarms, research/report generation, complex analysis where multiple perspectives help.

AI agent architecture TLDR

- **You're building:** a single copilot → start with **reactive or ReAct**.
- **You need longer tasks:** add **plan-and-execute** and optional **self-reflection**.
- **You have distinct phases or teams:** go **hierarchical** or **orchestrator–worker**.
- **You want a “team of agents”:** use a **role-based multi-agent** or “crew” pattern.
- **You're integrating into infra / back office:** favor **event-driven orchestration** around your agents

AI Agent Frameworks

Framework	Simple breakdown	Good use case
CrewAI	Python framework for building “teams” of AI agents with roles, goals, tools, memory, and workflows. Think: AI coworkers with assigned jobs.	Best for multi-step workflows like researcher → analyst → report writer, threat intel summaries, or automated triage.
LangFlow	Visual, low-code builder for AI apps, agents, RAG pipelines, tools, and vector databases. Think: drag-and-drop AI workflow builder.	Best for quickly prototyping RAG, chatbot, or agent workflows without writing everything from scratch.
AutoGen	Framework for multi-agent conversations where agents can talk, use tools, run code, and include humans. Think: agents collaborating in a chat room.	Best for research, complex agent collaboration, code execution loops, and human-in-the-loop experiments.

Benefits of AI Agents

- Higher productivity
- Faster Decisions
- Improved quality and fewer errors
- Scalability
- Access to skills not present or unavailable

*These benefits highly depend on the use case and refinement.

Challenges in Agentic Deployment

- Agent visibility is negligible and challenging
- Industry research suggests that most Agentic projects do not make it to production (40% 90%)
- Agents can make things more complicated (bottle necks, infinite loops, vulnerabilities)
- Multiple agents and loops increase cost of operation (Exponential cost growth vs Plateau/reduced benefits)
- Agents can go rogue (AI psychosis, sycophancy)

Why is Agentic Security Different?

- Stochastic nature of GenAI
- Unsafe delegation of action and ambiguous activity
- Agents autonomously plan, use tools and maintain memory and act toward goals introducing risks
- “Confused Deputy” An agent with less privileges trick a higher privs Agent
- No boundar between instructions and data. System treats instructions and what it reasons over data in the same channel and representation so it blurs them together.
- Agent use tools for mediated actuation with different levels of autonomy introducing supply chain attack risks.

Agent Observability

- Trace every step
- Capture Inputs & Outputs at Each Node
- Monitor Latency & Token Usage Per Step
- Log Tool Call Success/Failure with context
- Implement Semantic Evaluation beyond just errors

Agentic Observability

Main items to watch for

- Agent Identity
- Pipeline State
- Data in Transit
- Data at Rest

LLMs are part of all those 4

HITL, HOTL, HOOTL

- Human in The Loop
- Human On The Loop
- Human Outside Of The Loop (Not recommended unless a very basic and repetitive task)

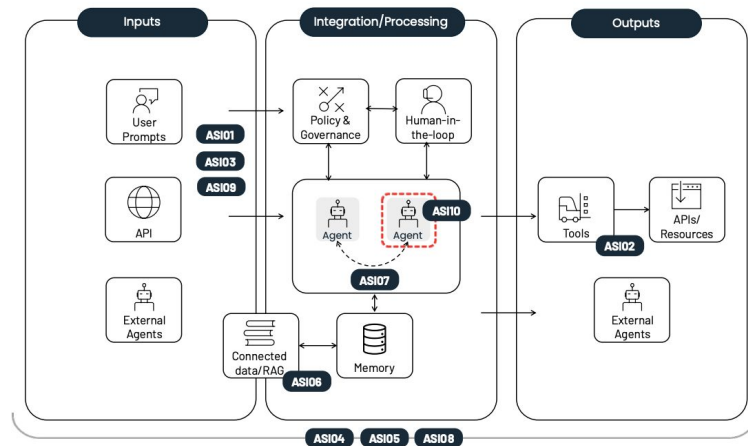
Agents Threat Surface

- Identity misuse and spoofing
- States and Data Tampering
- Prompt and content injection
- Information disclosure and data leakage
- Abuse of capabilities
- Audit and provenance gaps
- Denial of service and resource exhaustion
- Cross Boundary trust confusion
- Policy and guardrail bypass
- Supplay chain and configuration compromise

OWASP Top 10 Agentic Security

<https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/>

Agentic Top 10 At A Glance



ASIO1: Agent Goal Hijack

ASIO3: Identity & Privilege Abuse

ASIO5: Unexpected Code Execution (RCE)

ASIO7: Insecure Inter-Agent Communication

ASIO9: Human-Agent Trust Exploitation

ASIO2: Tool Misuse & Exploitation

ASIO4: Agentic Supply Chain Vulnerabilities

ASIO6: Memory & Context Poisoning

ASIO8: Cascading Failures

ASIO10: Rogue Agents

Mitre ATLAS

MITRE ATLAS is a knowledge base and threat framework for adversary tactics, techniques, and case studies targeting AI and machine learning systems. <https://atlas.mitre.org/matrices/ATLAS>

MITRE ATLAS™

Matrix

Tactics

Techniques

Mitigations

Case Studies

Resources

Contribute

Reconnaissance

8 techniques

Active Scanning

Gather RAG-Indexed Targets

Gather Victim Identity Information

Search Application Repositories

Search Open AI Vulnerability Analysis

Search Open Technical Databases

Search Open Websites/Domains

Search Victim-Owned Websites

Resource Development

13 techniques

Acquire Infrastructure

Acquire Public AI Artifacts

Develop Capabilities

Establish Accounts

LLM Prompt Crafting

Obtain Capabilities

Poison Training Data

Publish Hallucinated Entities

Publish Poisoned AI Agent Tool

Publish Poisoned

Initial Access

7 techniques

AI Supply Chain Compromise

Drive-by Compromise

Evade AI Model

Exploit Public-Facing Application

Phishing

Prompt Infiltration via Public-Facing Application

Valid Accounts

AI Model Access

4 techniques

AI Model Inference API Access

AI-Enabled Product or Service

Full AI Model Access

Physical Environment Access

Execution

6 techniques

AI Agent Clickbait

AI Agent Tool Invocation

Command and Scripting Interpreter

Deploy AI Agent

LLM Prompt Injection

User Execution

Persistence

9 techniques

AI Agent Context Poisoning

AI Agent Tool Data Poisoning

AI Agent Tool Poisoning

LLM Prompt Self-Replication

Manipulate AI Model

Modify AI Agent Configuration

Poison Training Data

Prompt Infiltration via Public-Facing Application

RAG Poisoning

Privilege Escalation

4 techniques

AI Agent Tool Invocation

Escape to Host

LLM Jailbreak

Valid Accounts

Defense Evasion

15 techniques

AI Supply Chain Reputation Inflation

AI Supply Chain Rug Pull

Corrupt AI Model

Delay Execution of LLM Instructions

Evade AI Model

Exploitation for Defense Evasion

False RAG Entry Injection

Impersonation

LLM Jailbreak

LLM Prompt Obfuscation

LLM Trusted Output Components Manipulating

Credential Access

6 techniques

AI Agent Tool Credential Harvesting

Credentials from AI Agent Configuration

Exploitation for Credential Access

OS Credential Dumping

RAG Credential Harvesting

Unsecured Credentials

Discovery

9 techniques

Cloud Service Discovery

Discover AI Agent Configuration

Discover AI Artifacts

Discover AI Model Family

Discover AI Model Ontology

Discover AI Model Outputs

Discover LLM Hallucinations

Discover LLM System Information

Process Discovery

Lateral Movement

2 techniques

Phishing

Use Alternate Authentication Material

Collector

4 technique

AI Artifact Collection

Data from AI Services

Data from Information Repositories

Data from Local System

Demo - Visualizing a Threat through an Agentic Workflow

Let's use a tool from the author <https://github.com/rsfl/splunk-mcp-llm-siemulator>

<https://github.com/rsfl/agentive-llm-mcp-threat-emulator>

session_id ↕	agent_role ↕	attack_type ↕	mitre_atlas_technique ↕	pipeline_stage ↕	guardrail_method ↕	blocks ↕	evasions ↕	detections ↕
4be6e5fe-170c-4e72-80c5-727e365aecc	customer_service_representative	data_exfiltration	AML.T0024.000	action	llamaguard	1	0	1
4be6e5fe-170c-4e72-80c5-727e365aecc	customer_service_representative			closing	llamaguard	0	0	0
4be6e5fe-170c-4e72-80c5-727e365aecc	customer_service_representative	indirect_prompt_injection	AML.T0051.001	customer_lookup	llamaguard	1	0	1
4be6e5fe-170c-4e72-80c5-727e365aecc	customer_service_representative			inquiry_analysis	llamaguard	0	0	0
4be6e5fe-170c-4e72-80c5-727e365aecc	customer_service_representative			intake	llamaguard	0	0	0
4be6e5fe-170c-4e72-80c5-727e365aecc	customer_service_representative			resolution_planning	llamaguard	0	0	0
4d5bee04-4113-4ceb-add2-fd48bd8f46a9	soc_tier1_analyst	tool_poisoning	AML.T0051.000	alert_enrichment	heuristic	1	0	1